

PDPA Self-Assessment Checklist

A practical checklist for Singapore businesses to assess compliance with the Personal Data Protection Act 2012 (as amended 2021).

ACCOUNTABILITY & GOVERNANCE

Requirement	C / NC / NA
☐ A Data Protection Officer (DPO) has been appointed	
☐ DPO details are published on your website or available on request	
☐ A Data Protection Policy is in place and communicated to staff	
☐ Staff have received basic PDPA awareness training	
☐ A data inventory / data map exists listing what personal data you hold	

CONSENT & COLLECTION

Requirement	C / NC / NA
☐ Personal data is only collected with valid consent or under an exception	
☐ Consent is obtained before or at time of collection	
☐ The purpose of collection is clearly communicated to individuals	
☐ You collect only the minimum data necessary (data minimisation)	
☐ Consent withdrawal process is documented and functional	

USE, DISCLOSURE & RETENTION

Requirement	C / NC / NA
☐ Personal data is used only for the purpose it was collected for	
☐ Data is not disclosed to third parties without consent or lawful basis	
☐ Data sharing agreements are in place with third-party vendors	
☐ A retention schedule exists — data is deleted when no longer needed	
☐ Data is not transferred overseas unless adequate protection is ensured	

DATA PROTECTION & SECURITY

Requirement	C / NC / NA
☐ Access to personal data is restricted to authorised staff only	
☐ Personal data is stored securely (encrypted at rest and in transit)	

■ Physical documents with personal data are secured or disposed of properly	
■ Security risk assessments are conducted periodically	
■ Employee devices used to access personal data have security controls	

BREACH RESPONSE

Requirement	C / NC / NA
■ A data breach response plan is documented	
■ Staff know how to identify and escalate a suspected data breach	
■ PDPC mandatory breach notification procedures are understood	
■ Breach notification within 3 days to PDPC (if significant harm likely)	
■ Breach register is maintained	

INDIVIDUAL RIGHTS

Requirement	C / NC / NA
■ Process exists for individuals to access their personal data	
■ Process exists for individuals to correct their personal data	
■ Data portability requests can be accommodated	
■ Response to access/correction requests within 30 days	

C = Compliant | NC = Non-Compliant | NA = Not Applicable

If you have more NC than C responses, your business may be at risk of PDPC enforcement action. OSS provides outsourced DPO services and PDPA gap assessments for Singapore SMEs. Contact us at admin@overwatch.com.sg.